vm-grc-01 Mini System Security Plan

Nov 9, 2026 · @Tyrell

1. System identification

vm-grc-01 is a single Ubuntu server in Azure with no public IP, reachable only through Azure Bastion, built as a portfolio lab to demonstrate NIST SP 800-53 Rev. 5 control implementation and assessment.

Item	Value
System name	vm-grc-01 GRC Lab
System owner / ISSO	Tyrell Freeman
Cloud service model	IaaS (Microsoft Azure, Azure for Students subscription)
Region	West US 2 (resource group metadata: East US 2)
Resource group	rg-grc-lab
Operational status	Operational (stopped when not in use)
Built	2026-11-07
Purpose	Hands-on demonstration of a hardened, documented, assessed cloud system
Data processed	None. No personal, financial, or sensitive data is stored or processed
Users	1 administrator (azureadmin), no end users
Baseline	NIST SP 800-53 Rev. 5, assessed with the Azure Policy NIST SP 800-53 Rev. 5 initiative (v14.21.*)

Components: VM vm-grc-01 (Standard_B2ats_v2, Ubuntu 24.04 LTS, Trusted launch), VNet vnet-grc-lab (10.0.0.0/16), subnet snet-vm1 (10.0.1.0/24, private subnet), NSG nsg-vm, OS disk (Standard SSD, 30 GiB), SSH key resource vm-grc-01_key. Azure Bastion and a NAT gateway are deployed only for admin sessions and deleted afterward.

2. Security categorization (FIPS 199)

The system is categorized **Low** (high-water mark), because it holds no sensitive data and its loss would have limited effect on its single owner.

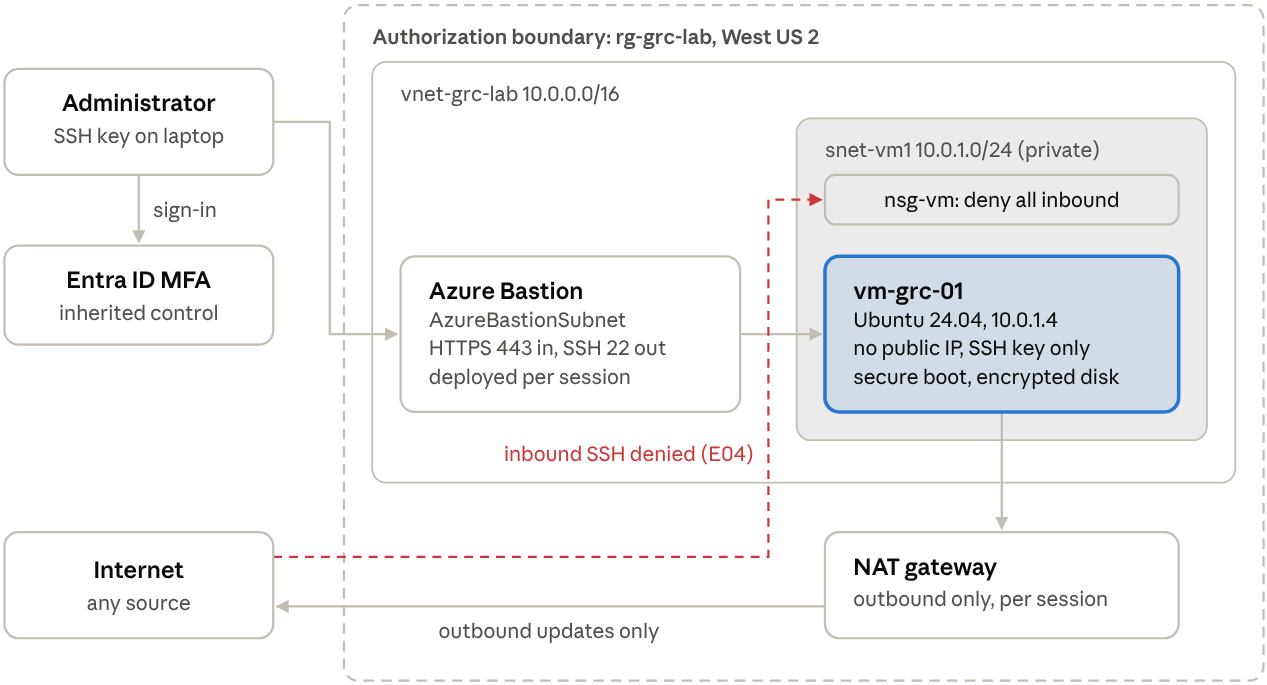
Security objective	Impact	Rationale
Confidentiality	Low	No sensitive or personal data. The only secrets are the admin SSH key (kept off the system) and Azure account credentials (protected by MFA).
Integrity	Low	Tampering would affect a lab system only. Trusted launch (secure boot, vTPM) protects the boot chain.
Availability	Low	No users depend on uptime. The VM is stopped daily by design and can be rebuilt.

Control baseline: NIST SP 800-53 Rev. 5 **Low** baseline is the target, but the Azure Policy initiative tests a broader set (Moderate and High controls included), so some findings exceed what a Low system strictly requires.

3. System boundary and architecture

The authorization boundary is resource group rg-grc-lab; the VM has no public IP, so the only way in is Azure Bastion, and the only way out is a NAT gateway that exists during admin sessions.

Only Bastion reaches the VM; inbound traffic from the internet is denied



vm-grc-01 architecture and authorization boundary

The administrator signs in to the Azure portal with MFA, opens a Bastion session over HTTPS, and Bastion connects to the VM's private IP on port 22. nsg-vm on the subnet denies all inbound traffic from the internet. Bastion and the NAT gateway are deleted after each session to control cost. Outside the boundary: the administrator's laptop, the St. John's Entra ID tenant, and Ubuntu's update servers.

4. Roles and inherited controls

Three parties share responsibility: Microsoft runs the cloud, St. John's University runs identity, and the system owner configures and operates everything inside the subscription.

Party	Role	Controls provided
Microsoft Azure	Cloud service provider (FedRAMP High authorized)	Physical and environmental protection (PE), hypervisor and host security, infrastructure DDoS protection (SC-5), platform encryption at rest (SC-28), Bastion service hardening
St. John's University	Identity provider (Microsoft Entra ID tenant) and subscription sponsor	MFA for portal sign-in (IA-2(1)), account lifecycle (AC-2), the subscription policy "Allowed resource deployment regions" (CM-7, SA-9)
Tyrell Freeman	System owner, administrator, ISSO	Network boundary, VM hardening, patching, access, cost guardrails, evidence and assessment (all controls in section 5 marked Customer or Shared)

Inherited controls are relied on, not tested. Evidence that they are in effect: E01 (MFA registered and enforced), B03c and E11b (region policy assigned and compliant).

5. Control implementation

Of the 22 controls documented here, 12 are implemented, 5 are partially implemented, 2 are planned, 1 is risk-accepted, and 2 are inherited; every gap has a POA&M item or a risk acceptance.

Control	Status	Responsibility	How it is implemented	Evidence
AC-17 Remote Access	Implemented	Shared	Admin access only through Azure Bastion (TLS 443) to the private IP. No public IP on the VM. Bastion is deployed per session and deleted after.	E02, E05
AC-17(3) Managed Access Control Points	Implemented	Shared	Bastion is the single managed entry point; no other path reaches port 22.	E04, E05
AC-3 Access Enforcement	Partially implemented	Customer	One admin account with sudo. OS file-permission checks pending the Guest Configuration agent.	E06; POAM-01
AC-6 Least Privilege	Partially implemented	Customer	Single admin role; root login with a key is still allowed in sshd.	E06; POAM-07
AU-2 / AU-12 Event Logging	Planned	Customer	Azure Activity Log (90 days, built-in) only. No Log Analytics workspace or VM log forwarding yet.	POAM-08

Control	Status	Responsibility	How it is implemented	Evidence
CA-2 / CA-7 Assessment and Monitoring	Implemented	Customer	Azure Policy NIST SP 800-53 Rev. 5 initiative assigned to rg-grc-lab; results exported and triaged. Network Watcher used to test the boundary.	E04, E11
CM-2 Baseline Configuration	Implemented	Customer	Build settings recorded at creation (size, image, Trusted launch, network, disk, tags).	B07, B09
CM-3 Configuration Change Control	Partially implemented	Customer	Changes logged in the evidence log with date and reason; review page checked before each deploy. Manual process, no IaC yet.	Evidence log; POAM-10
CM-6 Configuration Settings	Partially implemented	Customer	SSH hardened (password auth off). Azure compute security baseline not yet evaluated.	E06; POAM-01

Control	Status	Responsibility	How it is implemented	Evidence
CM-7 Least Functionality	Implemented	Shared	No public inbound ports; no services exposed. Subscription policy restricts deployable regions.	B07, E03
CM-8 System Component Inventory	Implemented	Customer	All resources tagged owner, environment, project in one resource group.	B01, E02
CP-9 System Backup	Risk accepted	Customer	No backup; system holds no unique data and will be rebuildable from code.	RA-01
IA-2 / IA-2(1) Identification and Authentication, MFA	Inherited	Inherited	Portal sign-in requires MFA through the St. John's Entra ID tenant (Authenticator push and passkey).	E01
IA-5 Authenticator Management	Implemented	Customer	SSH public key only (RSA key pair generated by Azure, private key held off-system). Password authentication disabled.	B07, E06
PE family Physical Protection	Inherited	Inherited	Provided by Microsoft data centers.	Microsoft FedRAMP package

Control	Status	Responsibility	How it is implemented	Evidence
RA-5 Vulnerability Scanning	Planned	Customer	Azure periodic patch assessment only; no vulnerability scanner.	E09; POAM-04
SC-5 Denial-of-Service Protection	Implemented	Shared	No public endpoint on the VM; Azure infrastructure DDoS protection inherited; DDoS Network Protection plan risk-accepted.	E02; RA-02
SC-7 Boundary Protection	Implemented	Customer	Private subnet; NSG nsg-vm at subnet level with default deny-all inbound; no custom allow rules. Outbound only through NAT gateway during sessions.	E02, E03, E04, B06, B12
SC-12 / SC-28 Protection at Rest	Implemented	Shared	OS disk encrypted at rest with platform-managed keys. Customer-managed keys and encryption at host planned.	E08; POAM-03

Control	Status	Responsibility	How it is implemented	Evidence
SI-2 Flaw Remediation	Implemented	Customer	apt update and upgrade each session; periodic patch assessment on. A silent patching failure was found and fixed (E07a to E07c).	E07a, E07b, E07c, E09
SI-7 Software Integrity	Partially implemented	Shared	Trusted launch with secure boot and vTPM on; integrity monitoring off.	B09; POAM-11
PM-3 / SA-2 Resource Allocation	Implemented	Customer	$20 monthly budget with alerts at 50, 80, 100 percent; daily auto-shutdown at 7:00 PM ET; paid components torn down after each session.	E09, E10, B14

6. Assessment results and open items

The 2026-11-09 Azure Policy scan found 24 of 970 NIST controls non-compliant, driven by 22 failing policies; after triage, only 6 are real gaps. After the first remediation round, a 2026-11-10 re-scan showed 19 failing policies and 19 failing controls, with 1 of 5 resources fully compliant.

Triage result	Policies	Meaning
Evaluation gap	12	Azure could not check the setting because the Guest Configuration agent or Defender for Servers is not installed. Several are contradicted by direct evidence (E04, E06).
Real gap	6	Customer-managed keys, encryption at host, vulnerability scanner, VM managed identity, Guest Configuration extension, NSG on the leftover AzureBastionSubnet.
Risk accepted	3	Backup, disaster recovery, DDoS Network Protection.
Not applicable	1	SQL Server vulnerability findings (no SQL installed).

Key finding (closed): on 2026-11-08, apt reported "All packages are up to date" while every repository fetch was timing out. The private subnet had no exit because the NAT gateway had no public IP. Adding the IP fixed it, and apt list --upgradable then returned nothing (E07a to E07c). Lesson: verify that a control works, not just that it is configured.

Open items are tracked in the POA&M (11 items, 1 closed) and risk register (10 risks) in vm-grc-01_POAM_Risk_Register.xlsx. Nearest milestones: managed identity and Guest Configuration agent, remove AzureBastionSubnet, and disable root login, all by 2026-11-15.

7. Evidence index

All evidence was captured 2026-11-07 to 2026-11-09; blur the subscription ID, billing scope ID, email, and phone number before publishing.

ID	What it shows	Controls
E01	MFA registered on the St. John's Entra account	IA-2, IA-2(1)
E02	VM overview: running, no public IP, private IP 10.0.1.4	SC-7, AC-17, CM-8
E03	nsg-vm inbound rules: defaults only, DenyAllInBound	SC-7, AC-17

ID	What it shows	Controls
E04	IP flow verify: internet to TCP 22 denied by DenyAllInBound	SC-7, AC-17, CA-7
E05	Bastion SSH session with key from local file	AC-17(3), IA-5
E06	sshd -T: password auth no, pubkey auth yes	IA-5, AC-17, CM-6
E07a to E07c	Patching: silent failure, fix via NAT gateway, empty upgradable list	SI-2
E08	Disk: Standard SSD, platform-managed key encryption	SC-28
E09	Auto-shutdown 7:00 PM ET; periodic patch assessment on	SI-2, PM-3
E10	$20 budget with 50/80/100 percent alerts	PM-3, SA-2
E11	Azure Policy NIST assignment, compliance summary, controls and policy exports	CA-2, CA-7, RA-5
B01 to B14	Build steps: resource group and tags, VNet, NSG association, VM review pages, Bastion, NAT gateway, teardown	CM-2, CM-3, CM-8

Files: screenshots in azure-vm-lab/evidence/, running notes in evidence-log.md, POA&M and risk register in vm-grc-01_POAM_Risk_Register.xlsx.